==========
CYBERSTART I RIGA TECHGIRLS I FINAL PROJECT
GRC Homework: Help Mike fix the mess
==========

From: Mike Oxmall
To: GRC Interns
Subject: URGENT-ish: need your help before the auditor shows up

Hey team,

Mike here,

Two things just landed on my desk:

1. A big EU bank client is sending us a vendor security questionnaire. They are “non-negotiable on documentation.”

2. Legal thinks we might be in NIS2 scope. The bank definitely is, so either way we have to act like we are.

Problem: our “information security policy” is one paragraph in the 2019 employee handbook. Our risk register is a Slack thread called #scary-stuff. Our incident process is “text Mike, panic.”

I cannot fix everything before the deadline. But I can fix ONE area properly, with real artifacts — if you help me.

You will work in groups of 3. Each person owns one piece. Then you peer-review another group’s work. Just like real GRC.

Don’t overthink it. I would rather have something honest and small than something fake and impressive.

Thanks. Pizza on me when it’s done.
— Mike

==========
STEP 1 — PICK ONE TOPIC (as a group)
==========

All three of you work on the SAME topic. Just pick one:

A. ACCESS CONTROL
Engineers share one AWS admin login. People who left months ago still have GitHub access. Nobody knows who approved what.

B. VENDOR / THIRD-PARTY MANAGEMENT
Marketing keeps signing up for new SaaS tools without telling anyone. The bank will ask which vendors touch
their data.

C. INCIDENT & BREACH HANDLING
Last month a developer emailed a customer list to the wrong client. We didn't know if we had to report it. We still don't.

D. BACKUP & BUSINESS CONTINUITY
Backups run nightly. Probably. Nobody has actually tried to restore one in 18 months.

==========
STEP 2 — SPLIT THE WORK (one role per person)
==========

——————————————————-
PERSON 1 — THE POLICY WRITER
——————————————————-

DELIVERABLE: A short Policy + Standard (half a page total).

– Policy: 3-5 sentences. What's the rule? Why? Who does it apply to?
– Standard: 4-6 specific, mandatory, TESTABLE requirements that support the policy.

——————————————————-
PERSON 2 — THE RISK & PROCESS OWNER
——————————————————-

DELIVERABLE: ONE risk register entry + ONE short procedure.

– Risk entry must include:
* Risk ID and short title
* Scenario in cause -> event -> effect format
* Affected asset/process
* Likelihood and Impact
* Risk owner (a ROLE, not a name)
* Treatment: retain / reduce / share / avoid
* One sentence justifying the treatment

– Procedure: 5-7 numbered steps describing how someone actually DOES the thing the policy demands.

——————————————————-
PERSON 3 — THE EVIDENCE & TICKET WRITER
——————————————————-

DELIVERABLE: Control-to-evidence map + ONE mock ticket.

– Control-to-evidence map:
* Pick ONE specific control from Person 1's standard
* List 3 pieces of evidence that would prove it
OPERATES (not just exists)
* One line per piece on why it is strong evidence (date? owner? scope?)

– Mock ticket. Include:
* Title
* Severity (Low / Medium / High / Critical)
* Affected system
* What was observed
* Next action
* Who to notify
Keep it under 150 words.

If your group picked Topic C (Incident), make the ticket
a breach assessment using confidentiality / integrity /
availability.

==========
WHAT TO SUBMIT
==========

Each group submits:

GROUP DOCUMENT (1 file, PDF or Word, 3-4 pages)
Contains all three artifacts. Put each person's name above their section.

==========
WHAT MIKE WILL ACTUALLY LOOK AT
==========

– Do all the artifacts connect? Same topic, consistent story?
– Is the risk specific enough to drive action? No "passwords
are bad."
– Could a stranger run your procedure?
– Is your evidence list believable?
– Did your peer review say something USEFUL?

——————————————————
Good luck. Don't be heroic, be honest. — Mike
——————————————————